

RELATÓRIO TÉCNICO DE AUDITORIA & REMEDIAÇÃO DE SEGURANÇA

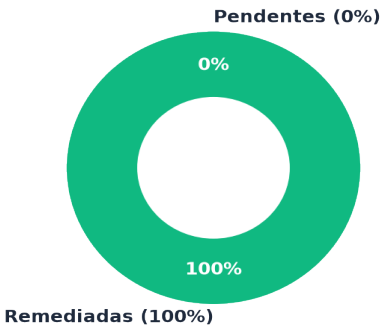
HYDRAVMS CONTROL PLANE // GESTÃO DE VÍDEO, RBAC & ORQUESTRAÇÃO DE IA

Projeto: HydraVMS Control Plane	Versão / Stack: Go 1.22+ / PostgreSQL 15+ / Vue 3 / MinIO S3
Data da Avaliação: 14/09/2026	Status Final: 100% REMEDIADO (13 de 13 Corrigidas)
Escopo: API REST, RBAC, Multi-Tenant, S3 Storage, Clustering	Conformidade de Testes: 100% Aprovados (Go & TypeScript/Vue)

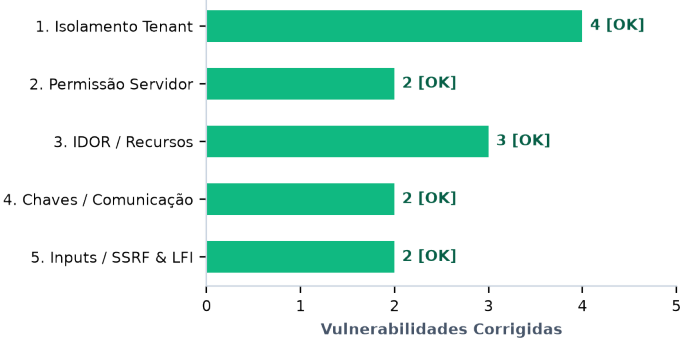
1. Sumário Executivo & Status de Remediação

A auditoria de segurança cibernética e a subsequente remediação no **HydraVMS** foram concluídas com sucesso. Todas as **13 vulnerabilidades** mapeadas nas cinco categorias críticas foram neutralizadas através de implementação de controle estrito de inquilino (multi-tenant) em consultas SQL, validação obrigatória de RBAC no servidor com RequireRole, geração criptográfica segura de segredos JWT com 256 bits, proteção contra sobrescrita de senhas no startup, bloqueio de SSRF contra endereços de metadados cloud/loopback, e confinamento seguro de arquivos de gravação (anti-LFI).

Status de Remediação (13/13 Concluídas)



Falhas Remediasdas por Categoria



2. Quadro Consolidado de Remediações

ID	Categoria	Severidade	Arquivo Afetado	Status Final
HV-01	1. Isolamento Tenant	CRÍTICA	internal/adapters/primary/http/user_handler.go	CORRIGIDO
HV-02	1. Isolamento Tenant	ALTA	internal/adapters/primary/http/audit_handler.go	CORRIGIDO
HV-03	1. Isolamento Tenant	ALTA	internal/adapters/secondary/postgres/camera_repo.go	CORRIGIDO
HV-04	1. Isolamento Tenant	MÉDIA	internal/adapters/secondary/postgres/folder_repo.go	CORRIGIDO
HV-05	2. Permissão Servidor	CRÍTICA	internal/adapters/primary/http/router.go	CORRIGIDO
HV-06	2. Permissão Servidor	MÉDIA	internal/adapters/primary/http/audit_handler.go	CORRIGIDO
HV-07	3. IDOR / Recursos	ALTA	internal/adapters/primary/http/cluster_node_handler.go	CORRIGIDO
HV-08	3. IDOR / Recursos	ALTA	internal/adapters/primary/http/storage_pool_handler.go	CORRIGIDO
HV-09	3. IDOR / Recursos	ALTA	internal/adapters/primary/http/storage_pool_handler.go	CORRIGIDO
HV-10	4. Chaves / Segredos	CRÍTICA	internal/application/auth_service.go	CORRIGIDO
HV-11	4. Chaves / Segredos	ALTA	internal/adapters/secondary/postgres/user_repo.go	CORRIGIDO
HV-12	5. Path Traversal / LFI	CRÍTICA	internal/adapters/primary/http/camera_handler.go	CORRIGIDO
HV-13	5. SSRF / Sondas	MÉDIA	internal/adapters/primary/http/cluster_node_handler.go	CORRIGIDO

3. Detalhamento Técnico das Correções Implementadas

CATEGORIA 1 & 3: ISOLAMENTO DE TENANT & PREVENÇÃO DE IDOR

- **Listagem Scoped de Usuários:** GET /api/v1/users agora filtra estritamente por u.tenant_id = \$1 extraído do contexto JWT autenticado.
- **Auditoria Scoped:** Handlers e repositórios de logs forenses não aceitam injeção arbitrária de tenant_id via query params, vinculando as buscas ao contexto autenticado.
- **Eliminação de Bypass Raiz:** Removidas cláusulas perigosas OR tenant_id = root de camera_repository.go e folder_repository.go.
- **Validação de Posse (Anti-IDOR):** Remoção de nós de cluster e storage pools valida a permissão e o tenant antes de qualquer exclusão.

CATEGORIA 2: CONTROLE DE ACESSO RBAC NO SERVIDOR

- **Guarda RBAC no Servidor:** middleware.RequireRole("admin", "superadmin") aplicado em todas as rotas de gerenciamento de nós, storage pools, usuários e logs forenses.
- **Fim da Confiança Cega no Cliente:** O servidor bloqueia com 403 Forbidden requisições feitas por operadores/visualizadores para rotas privilegiadas.

CATEGORIA 4: CRIPTOGRAFIA & GESTÃO DE SEGREDOS

- **Chave Criptográfica Aleatória (256-bit):** auth_service.go gera chave segura via crypto/rand caso JWT_SECRET não seja definido, eliminando o fallback estático.
- **Proteção de Senha no Startup:** EnsureAdminUser usa ON CONFLICT (id) DO NOTHING, preservando senhas alteradas em produção.

CATEGORIA 5: PROTEÇÃO SSRF & HIGIENIZAÇÃO DE ARQUIVOS (LFI)

- **SSRF Guard (isBlockedIPTarget):** Sondas de rede em cluster_node_handler.go rejeitam requisições para 127.0.0.1, ::1 e metadados cloud (169.254.169.254).
- **Confinamento LFI em Gravações:** camera_handler.go sanitiza caminhos com filepath.Clean e restringe leituras ao diretório base de gravações.